

04-NFR-Non-Functional-Requirements

NFR — Non-Functional Requirements (Supplementary Specification)

Leish! v2 — Beauty Booking Marketplace

1. Purpose
2. Performance Efficiency
3. Reliability
4. Security
5. Usability
6. Maintainability & Supportability
7. Portability & Compatibility
8. Compliance (Cross-Cut)
9. Operations & Observability
10. Constraints & Assumptions (NFR View)
11. Verification Matrix (Sampling)
12. Trade-offs & Rationale

NFR — Non-Functional Requirements (Supplementary Specification)

Leish! v2 — Beauty Booking Marketplace

FIELD	VALUE
Document ID	LEISH-NFR-v2.0
Version	2.0.0
Date	2026-08-29
Status	Baseline
Predecessor	SRS (02) §7
Standard	ISO/IEC 25010 (SQuaRE) quality model + OWASP ASVS

1. Purpose

Quantifies how well the system shall perform, not what it does. Every NFR here is **measurable** and has a stated **fit-criterion** (pass/fail) and **verification method**.

Categories follow ISO 25010: Performance Efficiency, Compatibility, Usability, Reliability, Security, Maintainability, Portability — plus Compliance & Operations.

2. Performance Efficiency

NFR-P-01 — RESPONSE TIME (LATENCY)

REQUIREMENT	TARGET (FIT-CRITERION)	PRIORITY	VERIFICATION
Public catalog <code>GET /api/artists</code> (cached 300s) p95	≤500 ms on Vercel + PG; ≤300 ms on cold-cache SQLite dev	Must	k6 / Vercel Analytics p95
<code>POST /api/bookings</code> (create, incl. slot check) p95	≤400 ms excluding async email send	Must	Load test 50 VUs
<code>GET /api/bookings</code> (scoped list, 20 rows) p95	≤350 ms	Must	Load test
<code>POST /api/payments/webhook</code> (verify+mark+settle) p95	≤300 ms	Must	Webhook replay bench
<code>PATCH /api/bookings/[id]</code> (state transition) p95	≤250 ms	Must	Unit bench
Admin dashboard aggregates <code>GET /api/admin</code> p95	≤800 ms (aggregated counts)	Should	Bench

Measurement: from Cloudflare/Vercel edge timing (`x-vercel-cache` , server-timing header if added) or `pino` request duration field.

NFR-P-02 — THROUGHPUT

REQUIREMENT	TARGET	VERIFICATION
Sustained bookings	10 rps (sustained) without error	Must
Webhook ingestion	20 rps burst for 60s (Billplz spike)	Must
Concurrent users (catalog)	500 concurrent (95% <500 ms)	Should

NFR-P-03 — CAPACITY & SCALABILITY

REQUIREMENT	TARGET	IMPLEMENTATION
Catalog growth	10k artists, 5k studios without schema change	Must
DB pool	PG_MAX 10 by default, configurable to 50 (Neon limits)	Must
Storage	Images via Supabase/Vercel Blob, not DB	Must
Horizontal	Stateless handlers (no session affinity); Redis optional for rate-limit	Must

NFR-P-04 — RESOURCE UTILIZATION

REQUIREMENT	TARGET	VERIFICATION
Vercel function memory	≤512 MB per invocation	Must
PG connections	P95 ≤ 80% of PG_MAX ; idle 10s timeout prevents pool exhaustion	Must
SQLite WAL	Enabled (PRAGMA journal_mode=WAL) for concurrent readers	Must

3. Reliability**NFR-R-01 — AVAILABILITY**

REQUIREMENT	TARGET	IMPLEMENTATION
Production uptime (monthly)	≥99.5% (≤3.6h downtime/mo) measured at GET / api/health externally	Must
Health endpoint	Responds <1s even when email/Billplz down (degraded mode)	Must

NFR-R-02 — FAULT TOLERANCE

REQUIREMENT	TARGET
DB pool error does not crash process	Must — <code>pool.on("error")</code> logs <code>pino.error</code> but keeps serving
Email provider failure degrades to <code>email_outbox</code>	Must — never throws from <code>sendEmail()</code> to caller route
Settings read failure falls back to defaults	Must — <code>getSetting()</code> catches and warns, never breaks payment math
Billplz API timeout → payment marked <code>required</code> (not <code>failed</code>) until webhook confirms	Must

NFR-R-03 — RECOVERABILITY

REQUIREMENT	TARGET
SQLite PG migration failure logs and throws (forces deploy rollback)	Must — <code>pgReady</code> catch logs and rethrows
Session JTI lookup failure (infra) is fail-open (accept valid signature) but logs warning — explicit <code>revoked=1</code> always wins	Must

NFR-R-04 — DATA INTEGRITY

REQUIREMENT	TARGET
Money never stored as float	Must — all <code>INTEGER</code> <code>sen</code>
Unique slot constraint enforced even under race	Must — partial index + friendly 409 catch
Rating blend without lost updates under concurrent reviews	Must — single UPDATE

4. Security

NFR-S-01 — AUTHENTICATION

ID	REQUIREMENT	FIT-CRITERION	VERIFICATION
S-01.01	Passwords script-hashed with random salt, timing-safe compare, optional pepper HMAC	No plaintext in logs/DB; <code>PEPPER_SECRET</code> rotates via <code>PEPPER_VERSION</code>	Code review + <code>src/server/auth.ts</code>
S-01.02	JWT HS256 with <code>SESSION_SECRET</code> 32-byte base64 in prod; 7-day TTL; JTI revocation table	<code>validateEnv()</code> throws if weak secret in prod; <code>revokeSession</code> clears JTI	Pentest + session tests
S-01.03	Cookie <code>leish_session</code> flags: <code>httpOnly</code> always, <code>Secure</code> in prod, <code>SameSite=lax</code> , <code>Path=/</code>	Header inspection	OWASP ZAP
S-01.04	No user enumeration on login/forgot-password	Constant-time response regardless of user existence	Auth tests

NFR-S-02 — AUTHORIZATION

ID	REQUIREMENT	FIT-CRITERION
S-02.01	<code>requireAdmin</code> guards every <code>/api/admin/*</code> ; <code>/admin/*</code> layout also server-guards before render	Must — 401/403 tests; <code>src/app/api/admin/list-routes.test.ts</code> audits coverage
S-02.02	Booking ownership: customer only sees <code>WHERE user_id=?</code> ; artist only sees claimed ids	Must — scope tests
S-02.03	Message SSE: participants only (<code>owner</code> OR <code>claimedArtist</code>)	Must — 403 for third party

NFR-S-03 — INPUT VALIDATION & INJECTION

ID	REQUIREMENT	FIT-CRITERION
S-03.01	All API inputs validated with <code>zod</code> via <code>registerSchema/loginSchema/bookingSchema/quotationSchema/artistsQuerySchema</code>	Must — zod rejects invalid before any DB touch
S-03.02	No SQL string concatenation for table names; <code>applyUpdate</code> field-map whitelist; values always via placeholders (<code>? / @name → \$n</code>)	Must — <code>ARTIST_UPDATE_FIELDS</code> whitelist
S-03.03	Billplz webhook verified via <code>verifyBillplzSignature</code> timing-safe before any state mutation	Must — reject 401 on bad sig; test suite covers tampered body

NFR-S-04 — SECURITY HEADERS & TRANSPORT

HEADER	VALUE	SOURCE
<code>Strict-Transport-Security</code>	<code>max-age=63072000; includeSubDomains; preload (prod)</code>	<code>next.config.ts</code>
<code>X-Frame-Options</code>	<code>DENY</code>	<code>next.config.ts</code>
<code>X-Content-Type-Options</code>	<code>nosniff</code>	<code>next.config.ts</code>
<code>Referrer-Policy</code>	<code>strict-origin-when-cross-origin</code>	<code>next.config.ts</code>
<code>Content-Security-Policy</code>	Per-request nonce, no <code>unsafe-inline</code> for scripts; inline theme script uses nonce/hashed	<code>next.config.ts</code> + <code>layout.tsx</code>
<code>Content-Type</code> charset	<code>utf-8</code> always	Next default

NFR-S-05 — RATE LIMITING & BOT PROTECTION

REQUIREMENT	FIT-CRITERION
Sliding window per IP on <code>register/login/forgot/verify-email/bookings</code> webhook — Upstash Redis when <code>UPSTASH_REST_URL</code> set, else in-memory	Must — 429 + <code>Retry-After</code> header
Turnstile widget (<code>NEXT_PUBLIC_TURNSTILE_SITE_KEY</code>) required for <code>register/login/forgot/bookings pay-*</code> when configured	Should — skip silently in dev/e2e when unset
<code>ALLOWED_ORIGINS</code> extra origins checked for state-changing requests	Should

NFR-S-06 — VULNERABILITY MANAGEMENT

REQUIREMENT	FIT-CRITERION
<code>npm audit</code> clean criticals at build; Dependabot auto-PRs	Must
ESLint <code>next</code> rules clean (<code>npm run lint</code> 0 warnings)	Must (CI gate)
Secret scanning: <code>github_run_secret_scanning</code> on PR	Must

5. Usability

NFR-U-01 — ACCESSIBILITY

REQUIREMENT	TARGET	VERIFICATION
WCAG 2.1 AA: color contrast $\geq 4.5:1$, keyboard navigation, screen-reader labels on filters/search	Must	Lighthouse a11y ≥ 90 ; manual axe-core
Form validation messages via zod surfaced inline; no raw zod dump	Must	Component tests
Dark/light theme preserved in <code>localStorage</code> with inline anti-CLS script; <code>prefers-reduced-motion</code> respected	Should	<code>src/lib/theme.tsx</code> + <code>layout.tsx</code>

NFR-U-02 — UX & CONTENT

REQUIREMENT	TARGET
Booking request completable in <90s (discovery → submit)	Should — measured via analytics funnel
Empty states with role-appropriate CTA ("Browse artists" vs "Claim a profile")	Must
Currency displayed via <code>formatRM(sen)</code> <code>src/lib/utls.ts</code> as <code>RM</code> <code>X.XX</code> consistently	Must
404 pages return true 404 (not 200 shell)	Must — no root <code>loading.tsx</code>

NFR-U-03 — INTERNATIONALIZATION

REQUIREMENT	TARGET
Date/times <code>en-MY</code> locale (<code>toLocaleDateString("en-MY")</code>)	Must — <code>formatDate</code> helper
Currency MYR only; English only at launch	Accept — i18n deferred

6. Maintainability & Supportability

NFR-M-01 — CODE QUALITY

REQUIREMENT	FIT-CRITERION
TypeScript <code>tsc --noEmit</code> 0 errors (<code>npm run typecheck</code>)	Must (CI gate)
Prettier formatted (<code>npm run format:check</code>)	Must (CI gate)
Coverage $\geq 80\%$ (<code>npm run test:coverage</code> HTML)	Must (quality-gate.yml)
<code>vitest</code> suite green; <code>playwright</code> e2e green on <code>chromium</code>	Must (CI + <code>ci.yml</code>)

NFR-M-02 — MODULARITY & DOCUMENTATION

REQUIREMENT	FIT-CRITERION
Money logic isolated to 4 modules only: <code>settings.ts</code> , <code>payments.ts</code> , <code>payouts.ts</code> , <code>quotations.ts</code> — route handlers must not compute amounts inline	Should — enforced by code review
Catalog source of truth clearly documented: <code>src/lib/data.ts</code> is seed-only , never runtime; runtime is <code>src/server/catalog.ts</code>	Must — AGENTS.md §1
Absolute imports <code>@/</code> enforced	Should — <code>tsconfig paths</code>

NFR-M-03 — OPERABILITY

REQUIREMENT	FIT-CRITERION
<code>LOG_LEVEL</code> env governs <code>pino</code> verbosity; JSON lines in prod, pretty in dev	Must
<code>reportError(err, ctx)</code> always logs structurally and optionally forwards to Sentry/webhook	Must
PG & SQLite schemas kept in sync; <code>detectSchemaDrift()</code> warns on divergence	Should
<code>npm run db:migrate</code> idempotent and also backfills additive columns (e.g. <code>payments.type</code>)	Must

7. Portability & Compatibility

REQUIREMENT	TARGET	VERIFICATION
Node ≥ 22 required (for <code>node:sqlite</code>) — <code>engines.node</code> in <code>package.json</code>	Must	<code>npm install</code> warns below 22
Runs on Vercel serverless (primary) and Docker <code>node:20-alpine</code> <code>standalone</code>	Must	<code>Dockerfile</code> multi-stage build
Browsers: last 2 evergreen; mobile-first responsive (<640px works)	Must	Manual device matrix
Env portability: same <code>.env.example</code> works for local (SQLite) and prod (PG) — behavior switches via <code>DATABASE_URL</code> presence	Must	<code>isPostgres()</code> check

8. Compliance (Cross-Cut)

AREA	NFR	FIT-CRITERION
PDPA	Consent recorded (<code>consent</code> + <code>consent_timestamp</code>), exportable, deletable	Must — see <code>docs/PDPA_RETENTION_GUIDELINES.md</code>
Financial	Settlements auditable for ≥7 years (payments/ payouts/quotations) even after user deletion (anonymized log)	Should
Privacy	No PII in logs (user names/emails redacted; IDs only)	Must
Accessibility	PDPA/Human rights — data never exposed to wrong user (scope queries)	Must

9. Operations & Observability

NFR-O-01 — LOGGING

REQUIREMENT	FIT-CRITERION
<code>logger</code> (<code>pino</code> 10.3) JSON in prod, pretty via <code>pino-pretty</code> in dev	Must
<code>LOG_WEBHOOK_URL</code> forwards JSON batch: 20 lines / 50ms debounce	Should
Every request logs route + userId (hashed if sensitive) + duration on error	Should

NFR-O-02 — MONITORING & ALERTING

REQUIREMENT	FIT-CRITERION
Sentry envelope POST when <code>SENTRY_DSN</code> set, else <code>ERROR_WEBHOOK_URL</code> POST fallback	Should — <code>src/server/errors.ts</code>
Agnost events for business funnel (register/login/booking/quotation/payment)	Should — dashboard <code>3e27e121-654d-4746-ba55-7996f21bb351</code>
<code>GET /api/health</code> polled by Docker + UptimeRobot (1m interval)	Must

NFR-O-03 — DEPLOYMENT

REQUIREMENT	FIT-CRITERION
<code>npm run build</code> succeeds with no errors (sets <code>NODE_ENV=production</code>)	Must — CI includes <code>ci.yml</code> build step
<code>npm run env:check</code> (production mode) reports missing <code>SESSION_SECRET</code> , <code>DATABASE_URL</code> , <code>POSTGRES_URL</code> , Billplz keys	Must — pre-deploy checklist AGENTS.md §Production Deployment
<code>npm run db:migrate</code> + <code>npm run db:seed-catalog</code> run successfully against target PG before first traffic	Must

10. Constraints & Assumptions (NFR View)

Inherited from SRS §2.5/2.6. Additional NFR constraints:

- Client `NEXT_PUBLIC_*` vars are the only ones exposed to browser; no secret may be `NEXT_PUBLIC_*` — enforced by review.
- Images must come from `*.supabase.co` (locked `images.remotePatterns`) — no arbitrary external domain.
- No background job runtime in serverless — must use stateless cron routes (`src/app/api/cron/*`) with `CRON_SECRET` guard.

11. Verification Matrix (Sampling)

NFR ID	METHOD	TOOL	PASS CRITERION
P-01	Load test	k6, Vercel analytics	p95 ≤ target
P-04	Config audit	Code review	<code>PG_MAX</code> , <code>idleTimeoutMillis</code> , WAL pragma present
S-03.03	Unit / contract	Vitest <code>verifyBillplzSignature</code> suite; ZAP	0 bypass cases
S-04	Header scan	<code>curl -I</code> + CSP evaluator	All headers present, no <code>unsafe-inline</code>
U-01	Accessibility	Lighthouse CI + axe	≥90 a11y, 0 critical
M-01	CI gate	GitHub Actions <code>quality-gate.yml</code>	All jobs green
O-02	Smoke	<code>curl /api/health</code> + Sentry dashboard	200 + no unreported error

12. Trade-offs & Rationale

DECISION	TRADE-OFF	RATIONALE
PG-first + SQLite fallback	Drift risk vs zero local setup friction	Chosen: drift detection + shared facade keeps both backends cheap; local DX wins
HS256 symmetric vs RS256 asymmetric sessions	Must share secret vs PKI rotation complexity	HS256 sufficient single-service platform; rotation via <code>SESSION_SECRET</code> redeploy
In-memory fallback for rate-limit when Upstash absent	Multi-instance inaccuracy vs deploy simplicity	Acceptable for preview/dev; prod sets Upstash
pino batch webhook vs structured OTEL	Simpler vs richer traces	Chose webhook forwarding to allow DataDog/ELK without SDK lock-in
<code>force-dynamic</code> for catalog vs ISR revalidation	Always-fresh vs CDN cache hits	Freshness wins for admin edits; public catalog still benefits from <code>s-maxage=300</code> on API layer

Next: `05-Use-Cases-and-User-Stories.md` maps these NFRs to user-visible scenarios with step-by-step flows.